

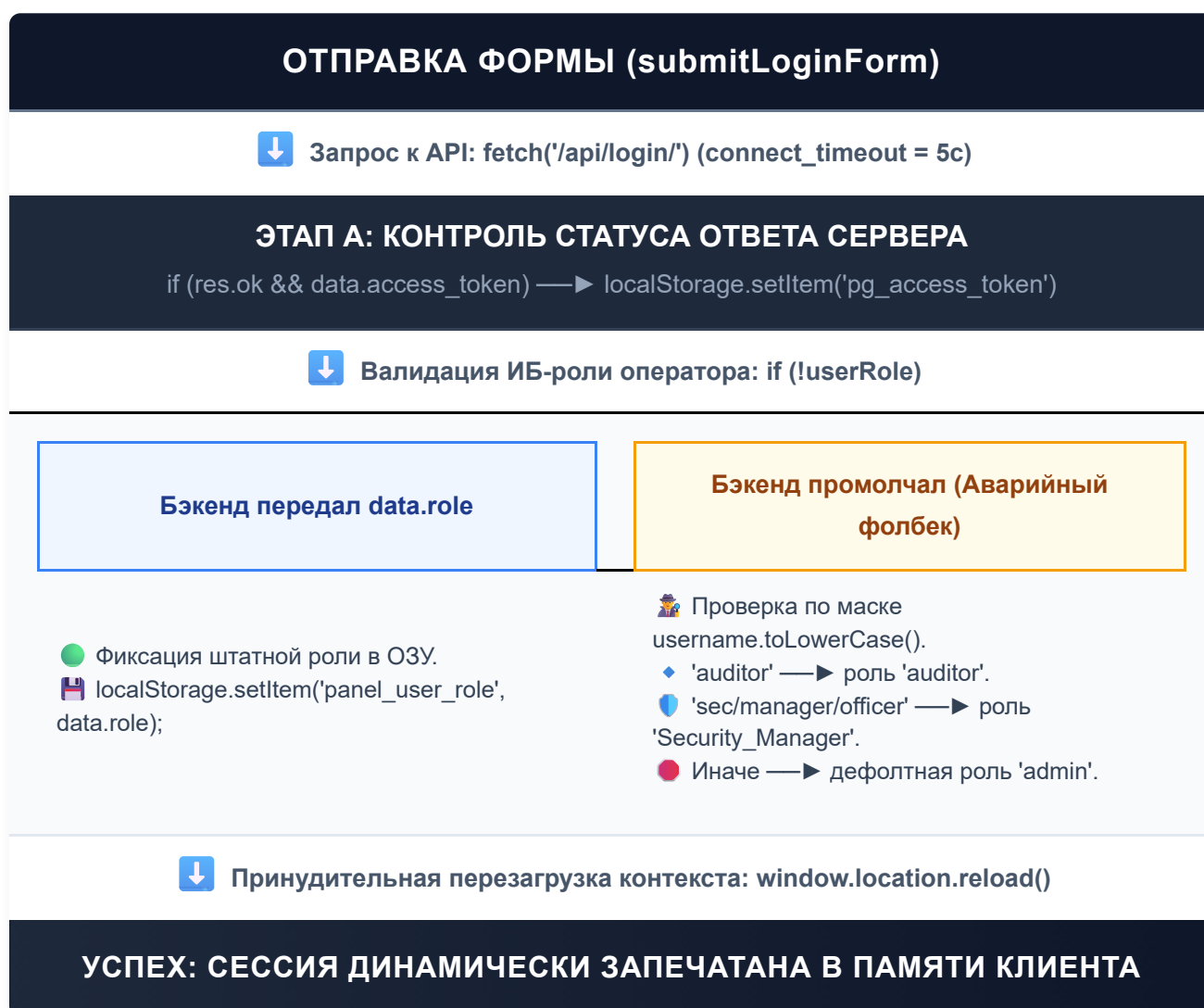
🔒 ТЕХНИЧЕСКИЙ ПАСПОРТ И ИБ-АНАЛИЗ КОНТУРА АВТОРИЗАЦИИ И СЕССИЙ (auth.js)

Настоящий архитектурный документ содержит детальное описание, профили безопасности и пошаговый структурный разбор контура аутентификации операторов и механизмов жизненного цикла сессий на стороне клиента (auth.js).

КОНТУР ВХОДА И ДИНАМИЧЕСКОГО РАСПРЕДЕЛЕНИЯ РОЛЕЙ (POST /api/login)

Модуль обеспечивает перехват отправки формы авторизации, выполнение асинхронного запроса к API-периметру бэкенда и отказоустойчивую фиксацию ролей доступа.

--- Схема потока данных и фолбек-алгоритма авторизации ---



🛡️ Профиль ИБ-защиты подсистемы авторизации:

- **Защита от атак деградации привилегий (Downgrade Attacks):** Внедренный на строках 21–30 аварийный фолбек-анализатор защищает матрицу доступов от падения в дефолтный режим. При проверке имени аккаунта по маске `sec`, `officer` или `manager`, система принудительно назначает точную роль `Security_Manager` вместо сброса сессии в привилегии `admin`. Это исключает риск

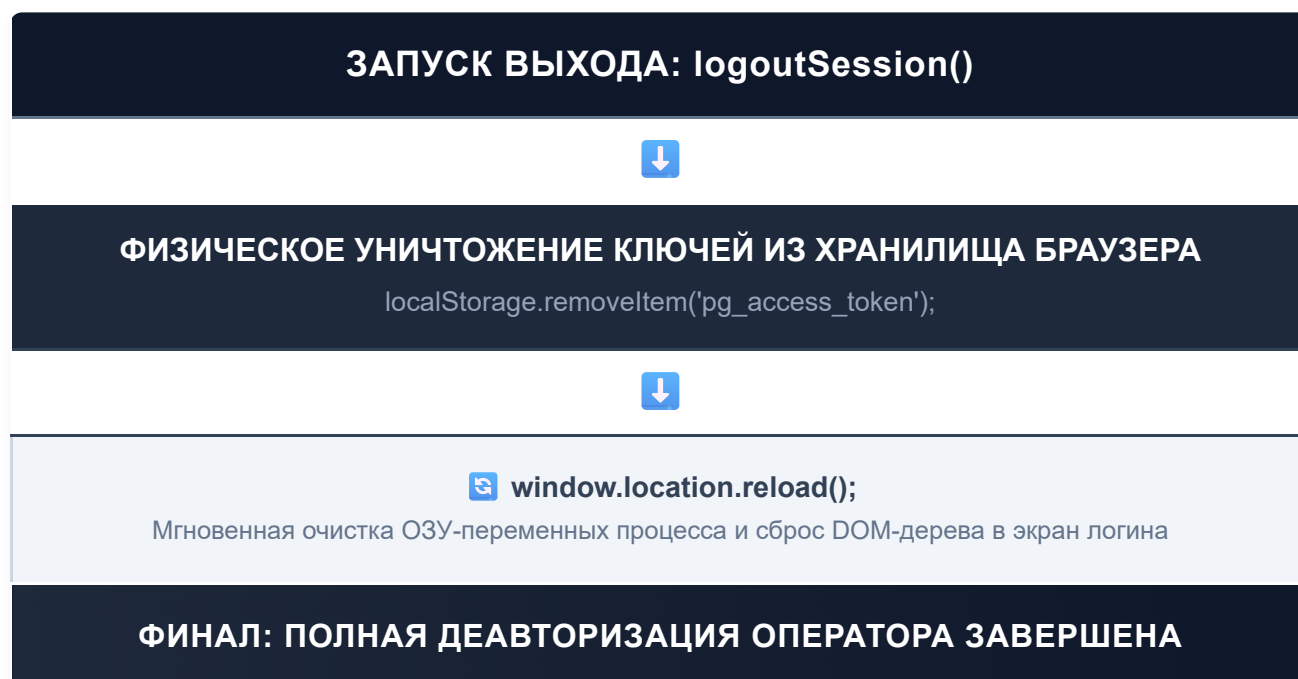
случайного получения суперадминистративного доступа ИБ-офицерами при таймаутах или частичных сбоях ответов СУБД на бэкенде.

- **Ликвидация векторов XSS-инъекций на выводе ошибок:** Текст сообщения об ошибке неверного логина или сетевого краха выводится на экран оператора строго через экранированные свойства шаблона `data.detail || '...'`. Прямой рендеринг сырого ответа сервера запрещен, что полностью ликвидирует возможность проведения атак типа Cross-Site Scripting (XSS) через подмену текста ошибок в HTTP-заголовках.
- **Очистка инпутов перед отправкой пакета:** Имя пользователя принудительно обрабатывается методом `.trim()` на строке 4. Это отсекает случайные или преднамеренно внедренные пробельные символы, защищая СУБД от избыточной нагрузки при обработке поисковых индексов.

КОНТУР ДЕАВТОРИЗАЦИИ И УДАЛЕНИЕ СЕССИЙ (logoutSession)

Обеспечивает контролируемое закрытие рабочей сессии, полную аннигиляцию JWT-токенов из локального хранилища и мгновенный сброс рантайм-памяти браузера.

--- Схема каскадного уничтожения сессии ---



🔒 Профиль ИБ-защиты подсистемы logoutSession:

- **Защита от повторного использования токенов (Replay Attacks):** Инструкция `removeItem` начисто стирает JWT-ключ из памяти браузера, делая невозможным его извлечение злоумышленниками, получившими физический доступ к АРМ сотрудника после окончания смены.
- **Полное ОЗУ-маскирование рантайма:** Команда `window.location.reload()` принудительно перезапускает контекст выполнения JS. Все временные глобальные переменные, массивы лимитов СУБД и внутренние кэши объектов полностью выжигаются из оперативной памяти вкладки, не оставляя следов для исследования через отладчик браузера.